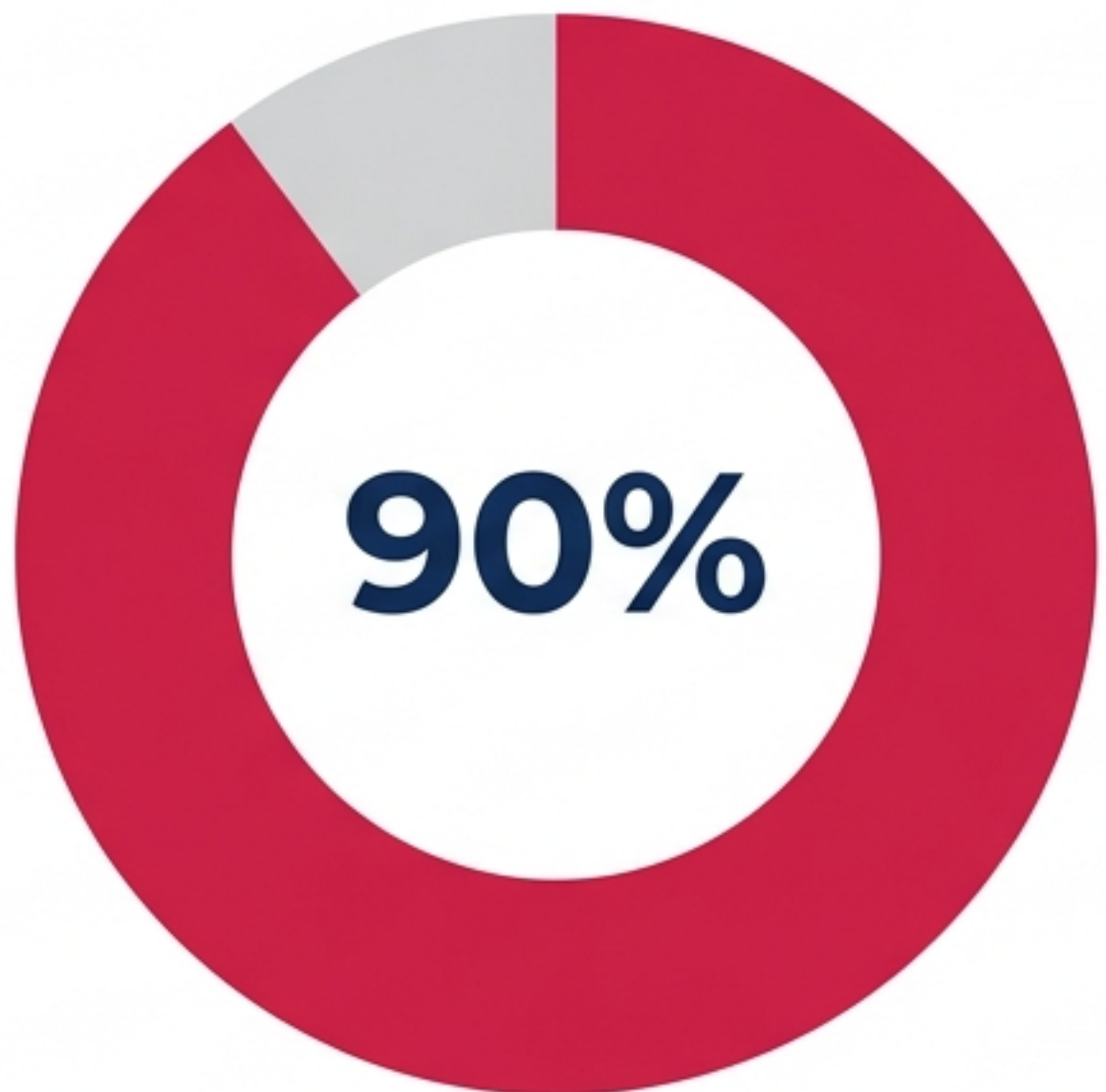


Information Gathering: Técnicas Avanzadas y Fuentes Abiertas

Módulo de Hacking Ético · OSINT

Presentado por Carlos Noboa

```
root@kali:~# ./osint_framework.sh --execute
```

La Regla 90/10 del Pentester

En un escenario real, un atacante empleará el 90% de su tiempo en elaborar un buen perfil de su objetivo y un 10% en lanzar el ataque.



MODULE: DIG (Domain Information Groper)

Dig: Interrogando al DNS

Dig es una herramienta nativa de Kali Linux diseñada para realizar consultas directas al Sistema de Nombres de Dominio (DNS).

Se utiliza en auditorías para recolectar información estructural de dominios y verificar configuraciones de registros DNS.

Arquitectura del Comando Dig

'**ANY**': Extrae todos los records disponibles.

'**+noall**': Oculta la salida por defecto (limpia la terminal).

'**+answer**': Muestra exclusivamente la sección de respuesta útil.

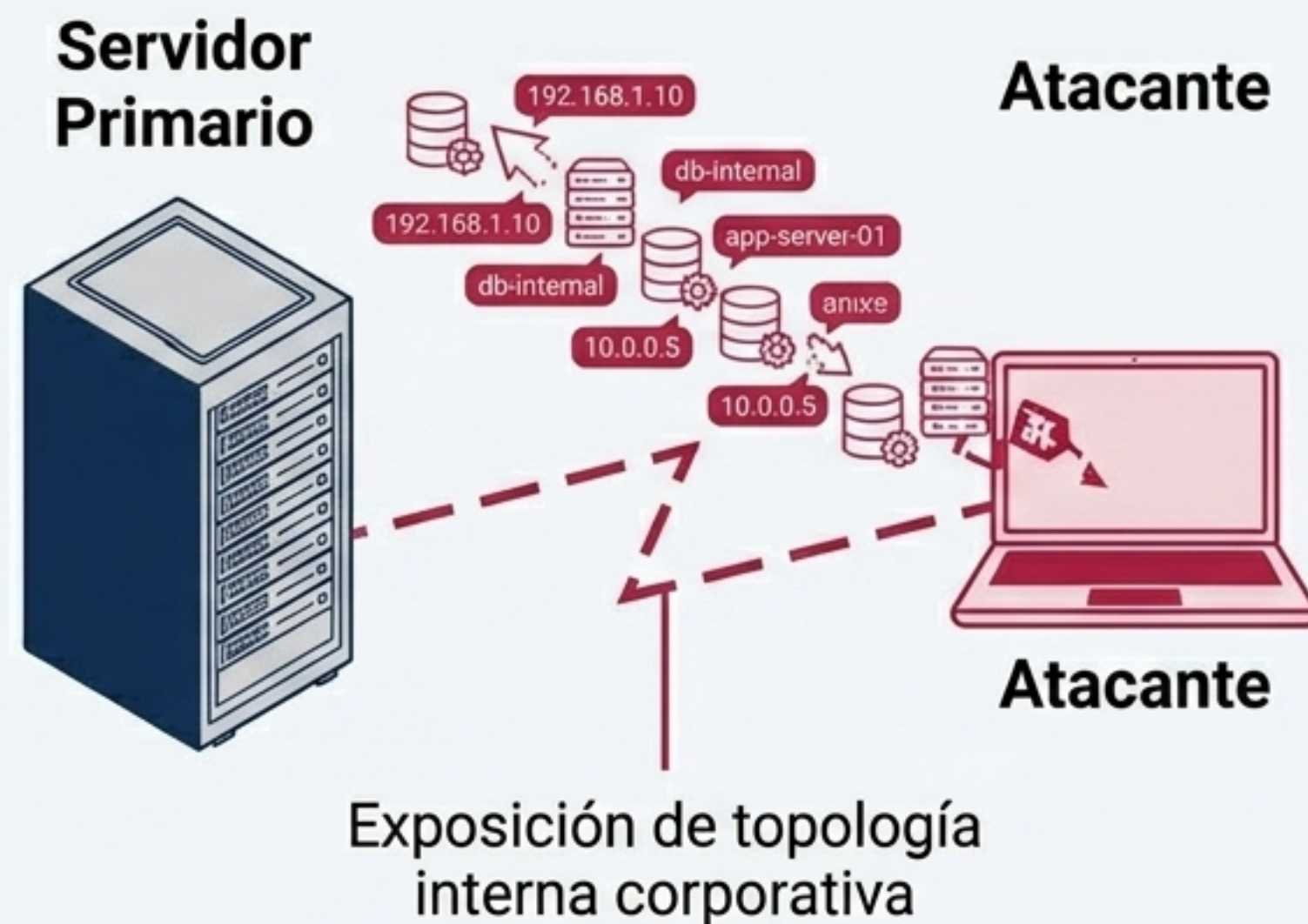
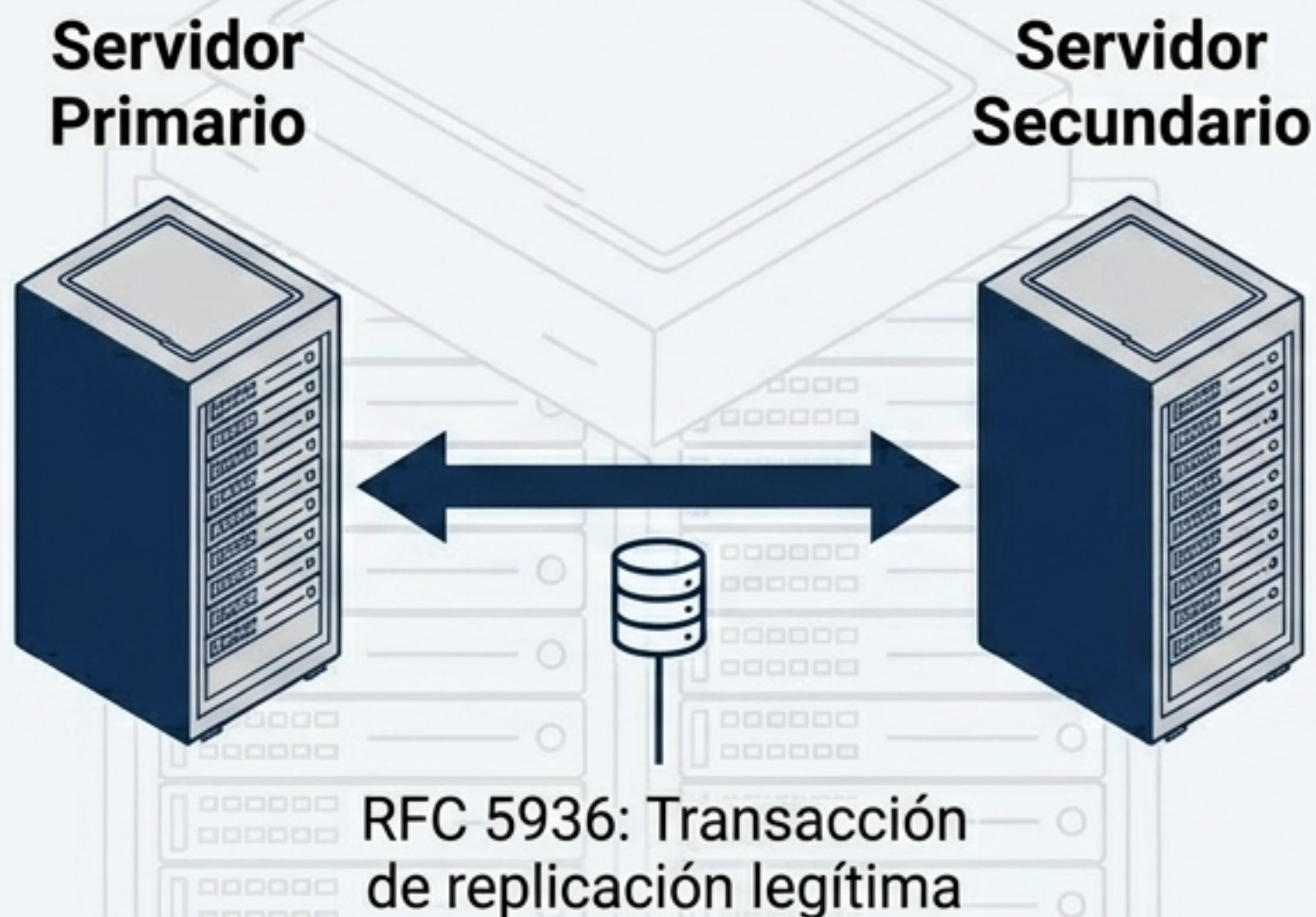
```
dig viu.es +noall +answer
```

'**+short**': Reduce la salida a solo las direcciones IP.

'**-x**': Ejecuta un reverse lookup (búsqueda inversa).

'**-f archivo**': Permite lanzar múltiples peticiones automatizadas desde un txt.

Transferencia de Zona (RFC 5936)



Una transacción diseñada originalmente para replicar bases de datos entre servidores DNS. Si está mal configurada, permite a un atacante mapear toda la topología de la red interna corporativa.

Explotación mediante parámetro 'axfr'

```
dig axfr @ns1.dominio.net dominio.net
```

```
dig axfr @nsztm1.digi.ninja zonetransfer.me
zonetransfer.me.          7200 IN   SOA nsztm1.digi.ninja.
admin.zonetransfer.me.    7200 IN   A    10.0.0.1
intranet.zonetransfer.me. 7200 IN   A    10.0.0.2
vpn.zonetransfer.me.      7200 IN   A    10.0.0.3
```

Regla de Seguridad: Las transferencias de zona deben permitirse únicamente desde otros servidores DNS del mismo dominio corporativo.

Google Hacking: Explotación del Rastreo

Los navegadores son herramientas de indexación de contenidos extremadamente eficaces.

Google Hacking utiliza filtros específicos para extraer información oculta o no intencionada que el Googlebot ya ha rastreado en dominios públicos.



Matriz de Sintaxis: Nivel Básico

IMPORTANTE: La evaluación de parámetros se ejecuta siempre de izquierda a derecha.

Operador	Función	Ejemplo de Búsqueda
Comillas ("")	Búsqueda exacta.	"Universidad Internacional de Valencia"
Guion (-)	Omisión de palabras clave.	"Universidad" -master
OR / AND	Condicionales múltiples lógicos.	"Universidad de Valencia" OR "Universidad Internacional"

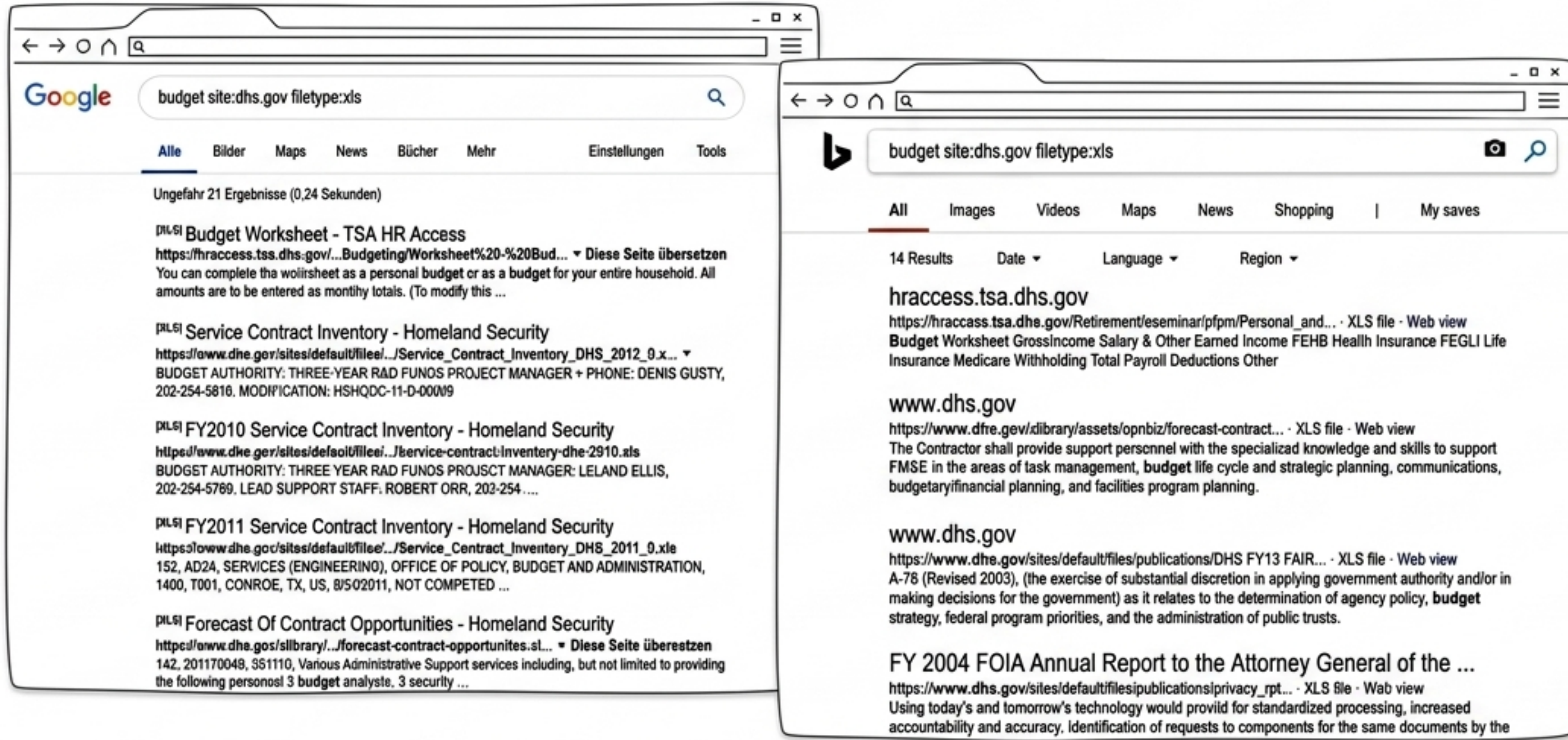
Matriz de Sintaxis: Nivel Avanzado

Operador	Función	Ejemplo de Hacking
intitle:	Busca cadenas específicas en el título de la página.	intitle:"Index of" "DCIM"
inurl:	Busca parámetros, directorios o rutas en la URL.	inurl:/intranet/login.php
filetype/ext:	Aísla y busca extensiones de archivo específicas.	filetype:xls budget

**Recurso:**
exploit-db.com/google-hacking-database

El Ecosistema Multi-Buscador

“**No todos los buscadores indexan igual.**”



Un pentester nunca debe limitarse a Google. Diferentes bots de rastreo (Bing, DuckDuckGo) tienen diferentes cadencias, reglas de exclusión y cachés, revelando documentos y vulnerabilidades que otros buscadores podrían haber pur

La Paradoja de Robots.txt

```
User-agent: Googlebot  
Disallow: /nogoogobot/
```

Intended Design



Attacker Reality



Archivo ubicado en el directorio raíz web para guiar a los rastreadores. Irónicamente, al declarar las URLs restringidas, proporciona a los atacantes un mapa directo de la arquitectura interna y rutas sensibles.

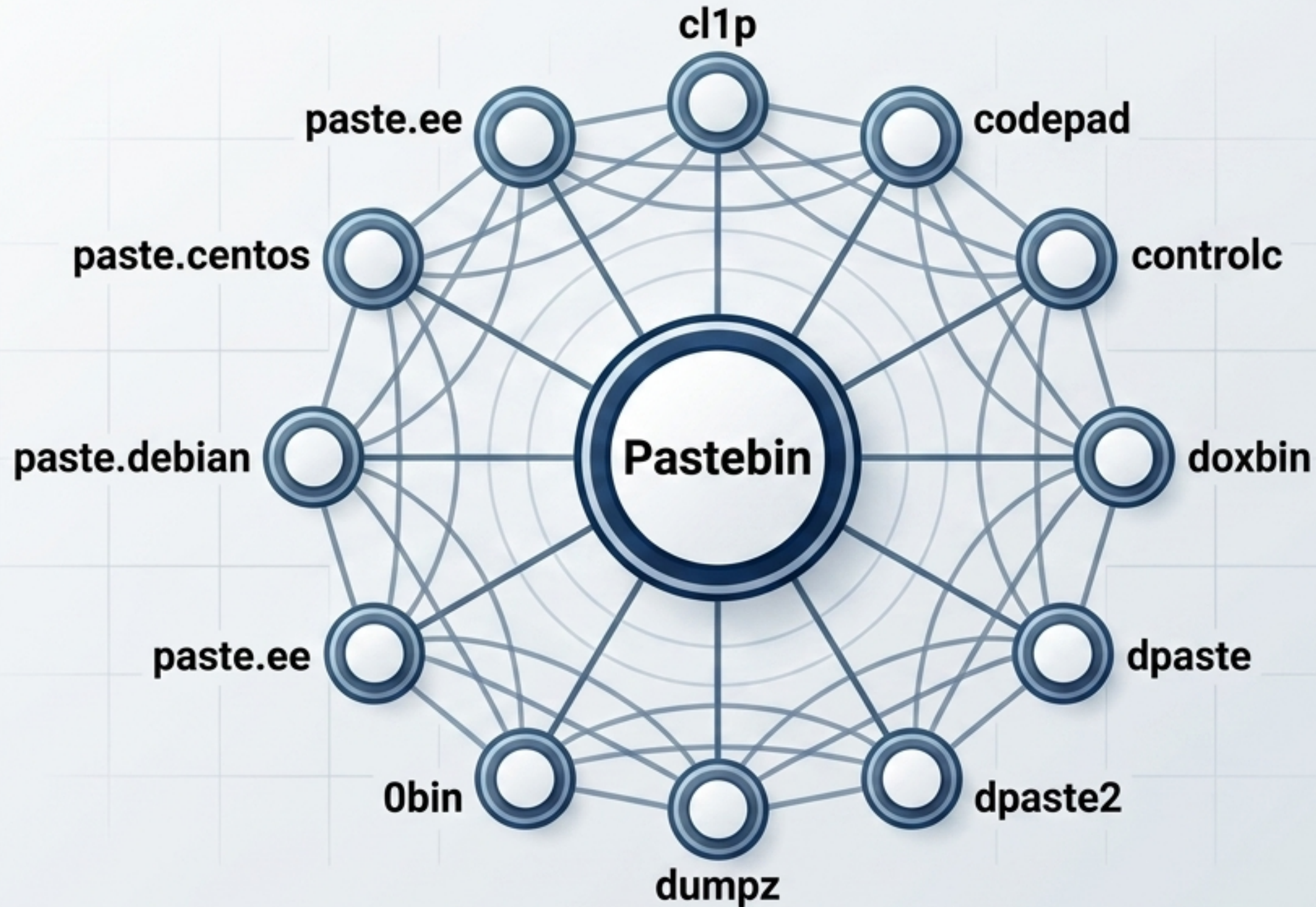
Pastebin y Fugas de Código

Aplicación web diseñada originalmente para compartir pequeños fragmentos de código fuente.

██████████@hotmail.com	Netflix	25.08.2018
██████████@hotmail.com	Netflix	25.08.2018
██████████@gmail.com	Netflix	25.08.2018
██████████@gmail.com	Netflix	25.08.2018
██████████@gmail.com	Netflix	25.08.2018
██████████@gmail.com	Netflix	25.08.2018
██████████@gmail.com	Netflix	25.08.2018

Actualmente, es uno de los repositorios principales donde se publican leaks masivos de información (contraseñas, código interno, credenciales) tras el compromiso de empresas. Buscador OSINT: **pastebin.ga**

El Ecosistema de Leaks Abiertos



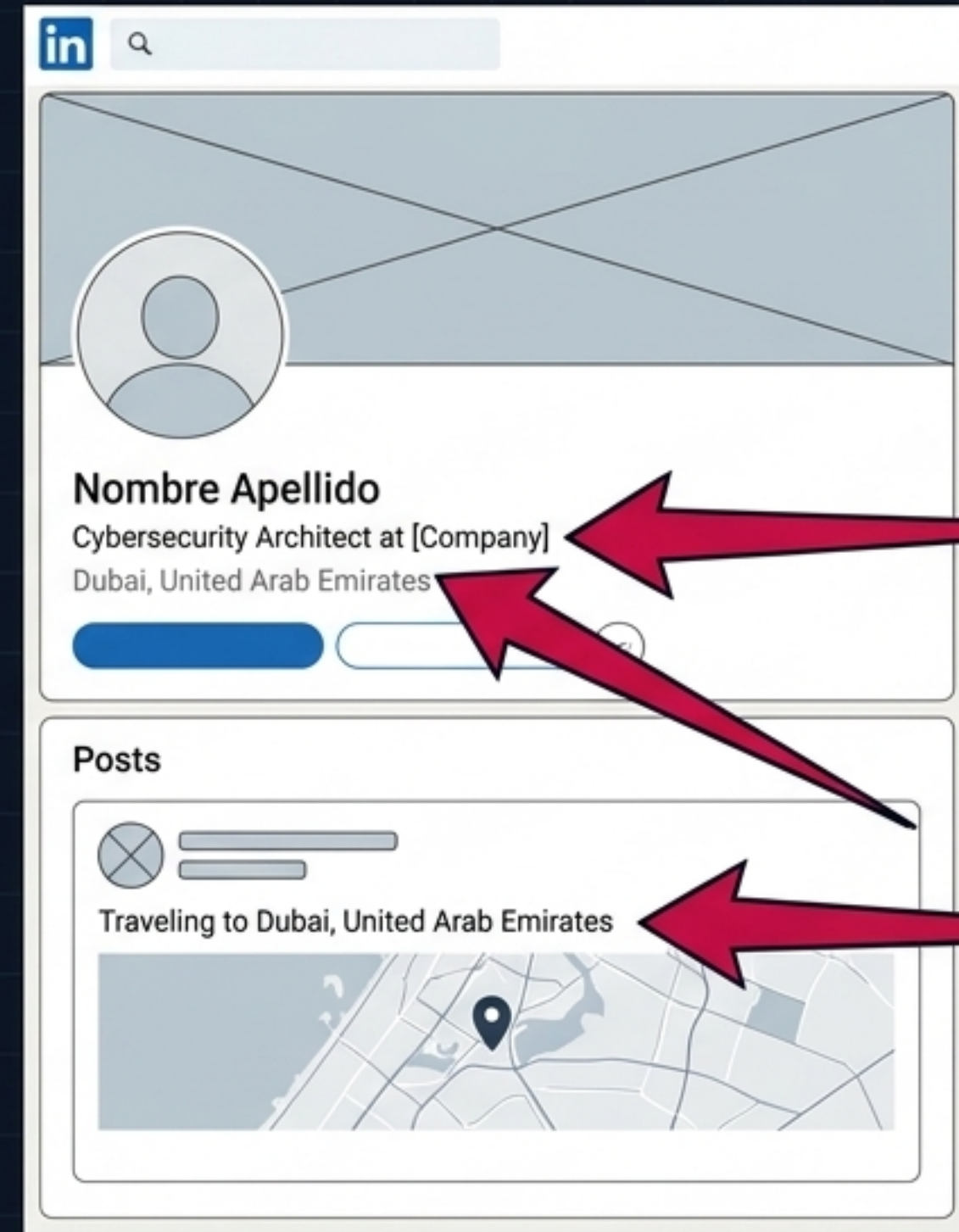
El rastreo de fugas exige monitorizar toda esta superficie de plataformas anónimas.

OSINT en Redes Sociales

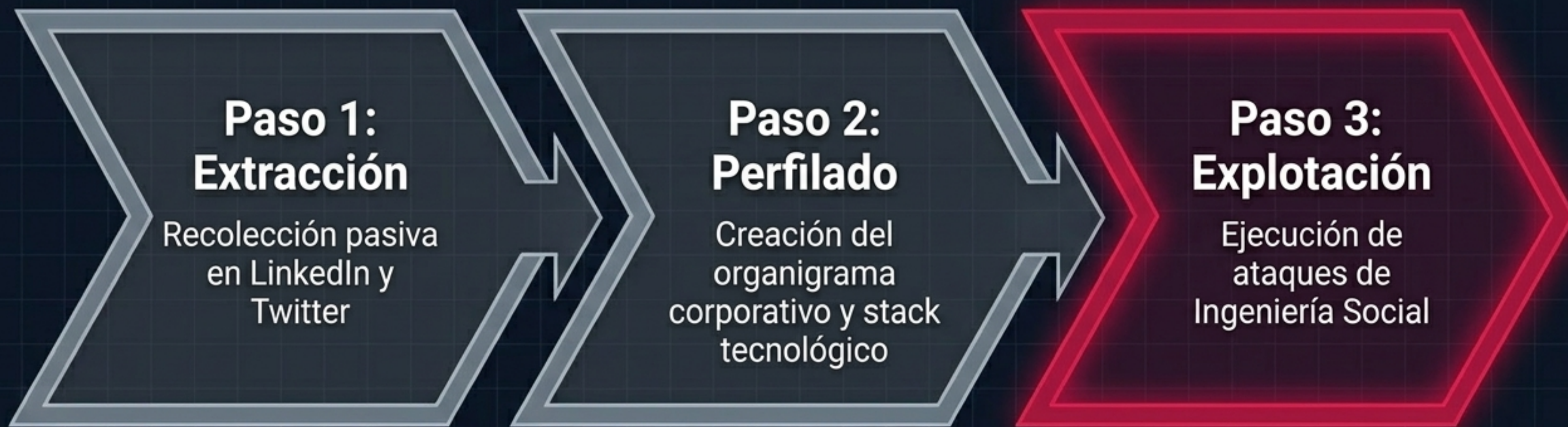
Plataformas como LinkedIn o Twitter permiten la recolección pasiva y anónima de inteligencia corporativa.

- Nombres de empleados y jerarquías.
- Estructuras de correo electrónico.
- Tecnologías internas (mencionadas en el CV).

Herramientas: Raven, Tinfoleak (tinfoleak.com)



El Vector de Ingeniería Social



La **información personal y profesional** recolectada en redes sociales es el insumo principal para elaborar campañas de Phishing o Spear-Phishing altamente personalizadas y creíbles.

Estrategias de Mitigación Global

Concienciación:

Entrenamiento de usuarios frente a ingeniería social y fugas en redes.

Auditoría (Pentests):

Ejecución periódica de pruebas ofensivas y escaneos de red.

Cifrado: Políticas estrictas de cifrado para información sensible (mitiga impacto de leaks).

Control de Acceso: Políticas de autenticación robustas.

Configuración Segura: Higiene en archivos expuestos (User-agent: *
Disallow: /< rutas>).



El Alcance del Information Gathering

“Las mayores vulnerabilidades no siempre requieren exploits complejos; a menudo, derivan directamente del error humano y de información pública mal gestionada.”